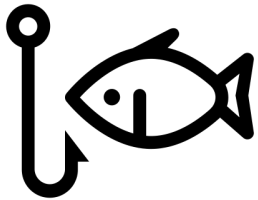


Analysis of Web3 Phishing Techniques

Thinking@slowmist.com & Cos@slowmist.com

Introduction

Web3 Phishing Attack Status & Defense Challenges



Attack Status

Attackers often disguise themselves as trending projects using lures such as airdrops or high returns to attract users. Methods include domain impersonation, social media fraud, and fake apps. They skillfully apply social engineering, using strategies to hide their true intentions.



Defense Challenges

Users find it hard to maintain constant vigilance. Even those with strong security awareness can fall victim to evolving and hard-to-detect phishing techniques. Attackers also excel at concealing identities and erasing traces, making tracking difficult.


Camouflage
Bait
Lure
Attack
Concealment
Technique
Identification
Defense

Camouflage

Filtering and Disguising Target Projects

Attackers research trending topics, project community activity, and user base size to identify "high-profile" targets. Their disguises include:

- Similar ~~(authentic)~~ domains and websites
- Fake ~~(authentic)~~ social media accounts or Telegram bots
- Impersonated ~~(authentic)~~ administrators
- .....

Methods for Attracting Attention

In the Web3 space, the tactic of "Do one thing under cover of another" is widely used.

On the surface, attackers disguise themselves as project teams by launching AMA sessions, airdrops, and other activities to attract social media attention. In reality, these are used to distribute "bait" in preparation for subsequent phishing attacks, leaving users defenseless.

Disguised identities: project official social media accounts, applications, websites, TG bots, or even well-known Web3 KOLs.

Hide the Attack Intent



The attacker's ultimate intention: steal assets / steal permissions -> steal assets.

Due to the previous buildup, users with poor security awareness are more likely to fall victim to subsequent attacks; even those with higher security awareness are not immune, as it's difficult to stay constantly vigilant. "You can't walk by the shore without getting your feet wet."

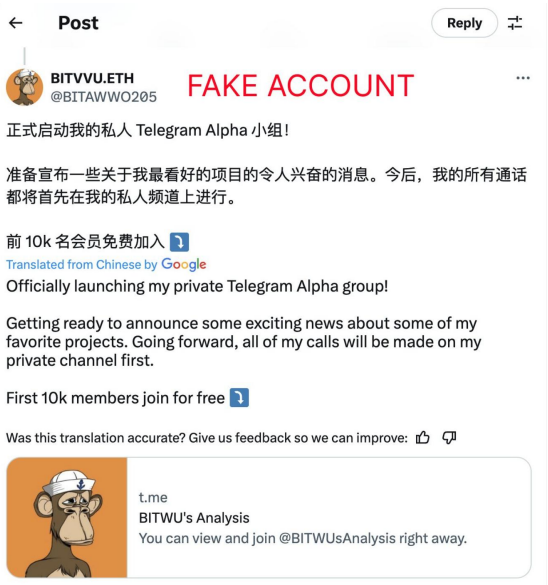
SLOWMIST

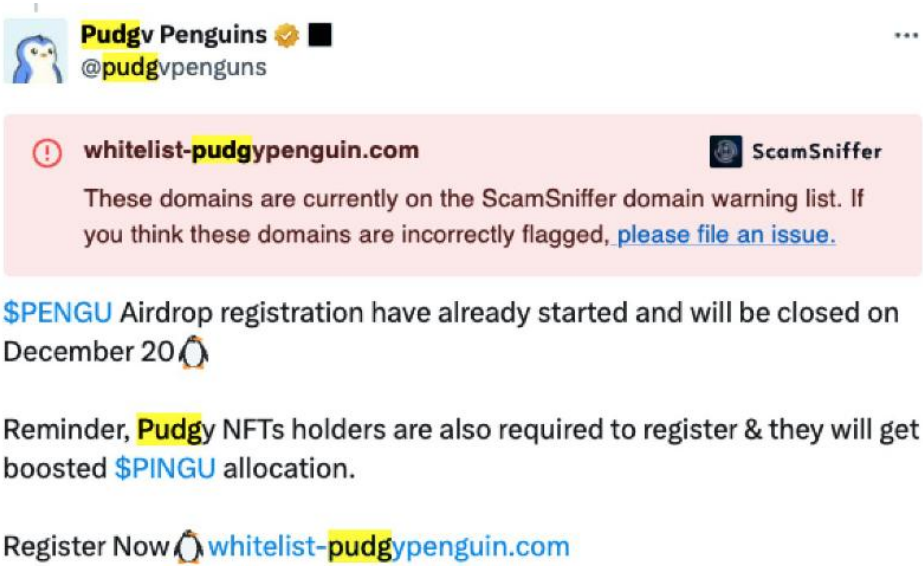
Hide the Attack Intent

- Stealing users' mnemonic phrases or private keys, such as deceiving users into entering their mnemonic phrases or private keys.
- Deceiving users into signing transactions with their wallet, such as authorization signatures, transfer signatures, etc.
- Stealing users' account passwords, such as for Telegram, Gmail, X, Discord, etc.
- Stealing users' social application permissions, such as for X, Discord, etc.
- Inducing users to install malicious programs, such as fake wallet apps, fake social apps, fake conference apps, etc.
- ...

Bait

Make Bait


Post
Reply
BITVVU.ETH
@BITAWWO205
FAKE ACCOUNT
正式启动我的私人 Telegram Alpha 小组！
准备宣布一些关于我最看好的项目的令人兴奋的消息。今后，我的所有通话都将首先在我的私人频道上进行。
前 10k 名会员免费加入
Translated from Chinese by Google
Officially launching my private Telegram Alpha group!
Getting ready to announce some exciting news about some of my favorite projects. Going forward, all of my calls will be made on my private channel first.
First 10k members join for free
Was this translation accurate? Give us feedback so we can improve:
t.me
BITWU's Analysis
You can view and join @BITWUsAnalysis right away.


Pudgy Penguins
@pudgypenguns
whitelist-pudgypenguin.com
ScamSniffer
These domains are currently on the ScamSniffer domain warning list. If you think these domains are incorrectly flagged, please file an issue.
$PENGU Airdrop registration have already started and will be closed on December 20
Reminder, Pudgy NFTs holders are also required to register & they will get boosted $PINGU allocation.
Register Now whitelist-pudgypenguin.com

Make Bait

Build scripts as bait to promote, inducing interaction with a story.

- Make users feel it's profitable, such as: Airdrop qualification whitelist, mining early tokens, keys to wealth, etc.
- Provide convenience to users, such as: tools for grabbing airdrops, AI quantification tools, one-click mining for yields, etc.

Bait Deployment: precise targeting

Deployment channels:

- Social apps: X, Telegram, Discord, etc.
- Search engines: Google, Baidu, Bing, etc.
- Email: SMTP server (Google, AWS) for bulk email distribution, etc.
- ~~App stores: Google Play, Chrome Store, App Store, APKCombo, etc.~~

Lure

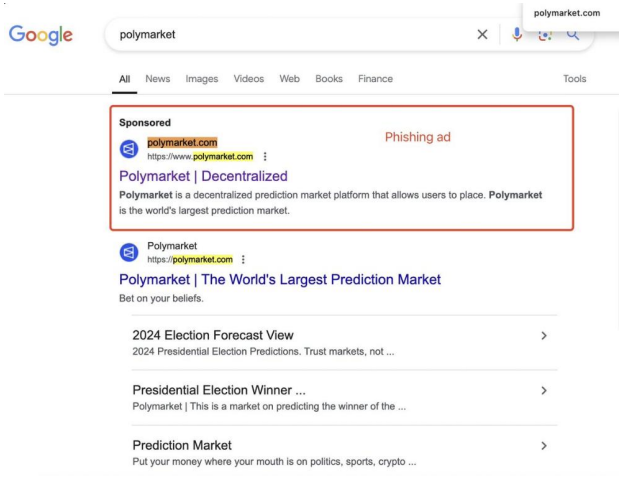
Bait Propagation: social media/search engine rankings

The attacker uses Web3 communities to post enticing ~~Token Airdrop event links~~ on Web3 social media, luring users to click and visit, thus beginning to "play out the script." The story typically involves completing a series of tasks to earn rewards, tricking users into "biting the hook."

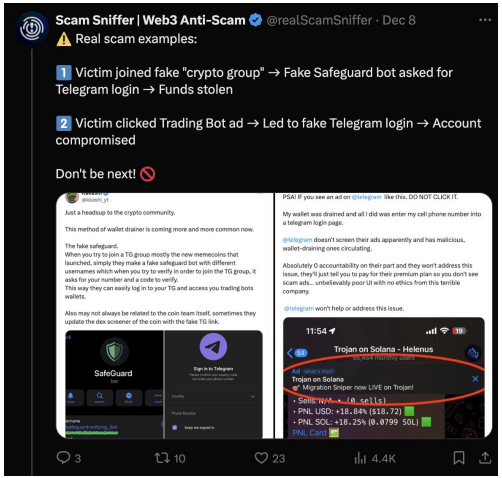
Deployment methods:

- Social platforms: Group chats, private messages, comments and replies, posting tweets, advertisements, etc.
- Search engines: SEO / running ads to boost rankings.
- ~~App stores: Listing counterfeit or fake apps.~~

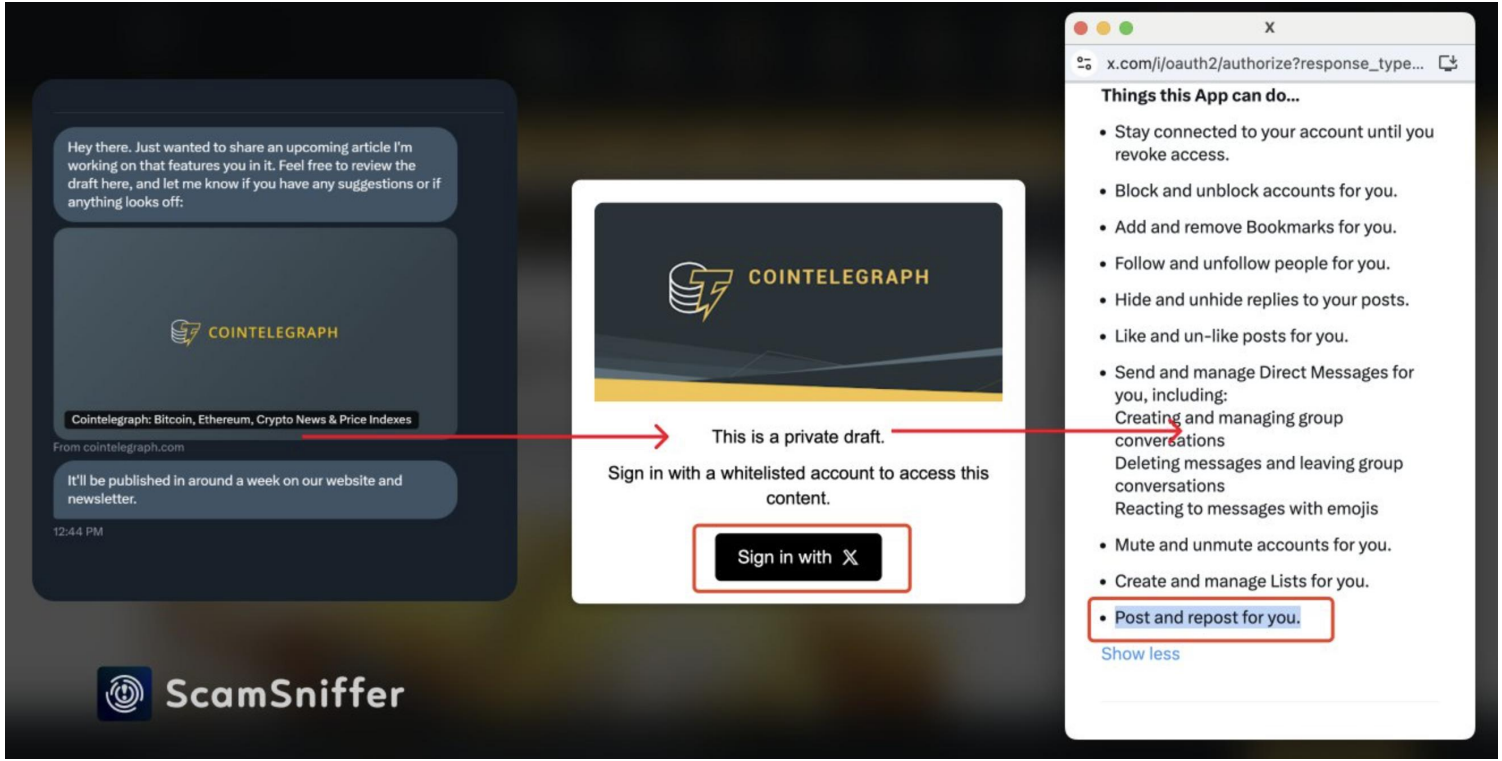
Bait Propagation: social media/search engine rankings



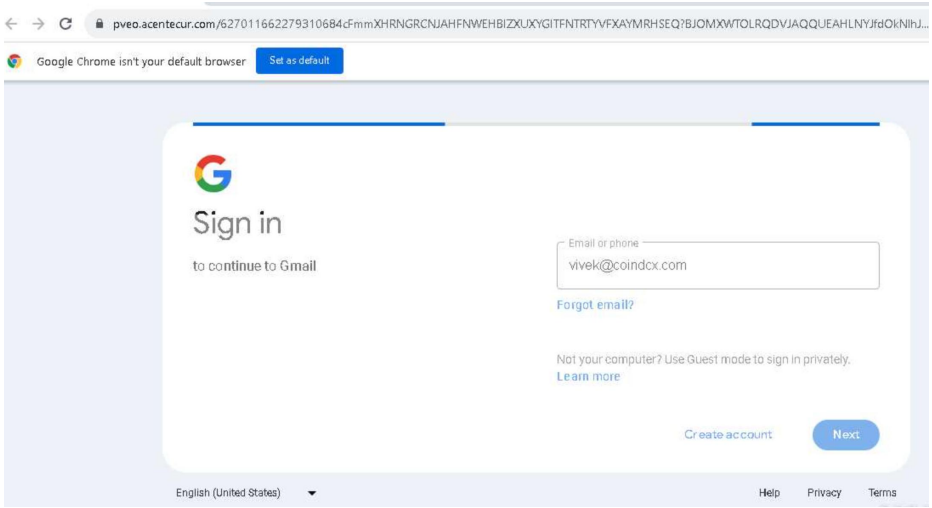


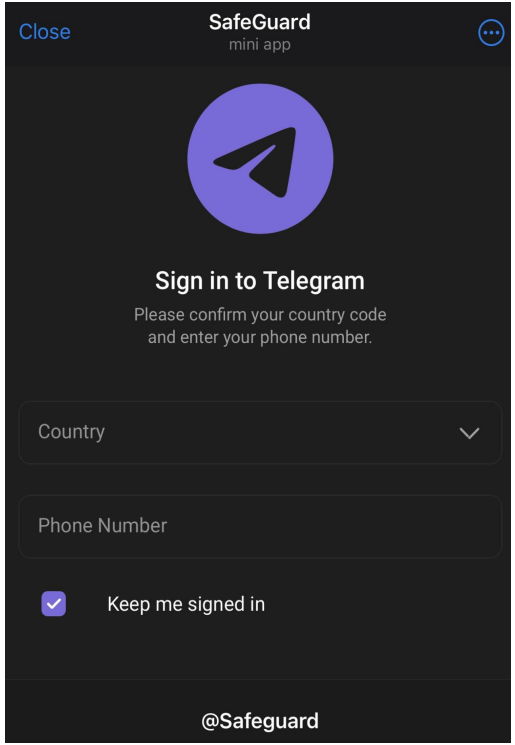


Social Engineering – unknowingly fall into the trap



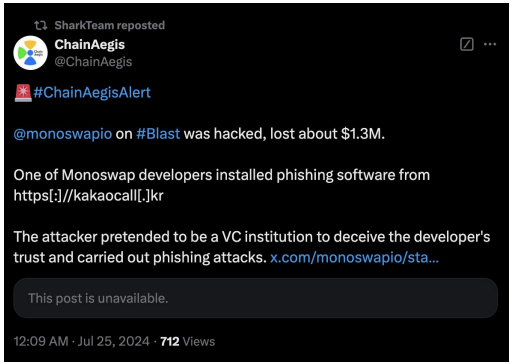
Social Engineering – unknowingly fall into the trap





Social Engineering – unknowingly fall into the trap





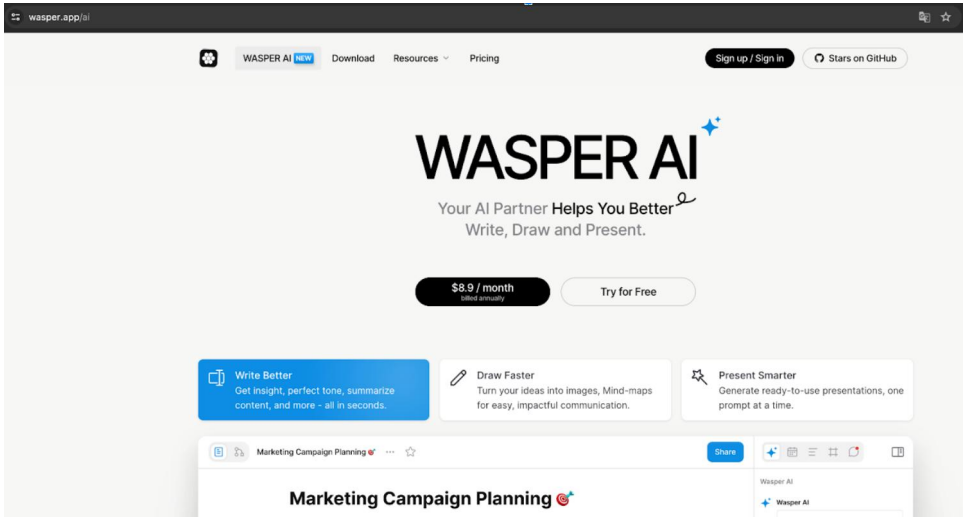




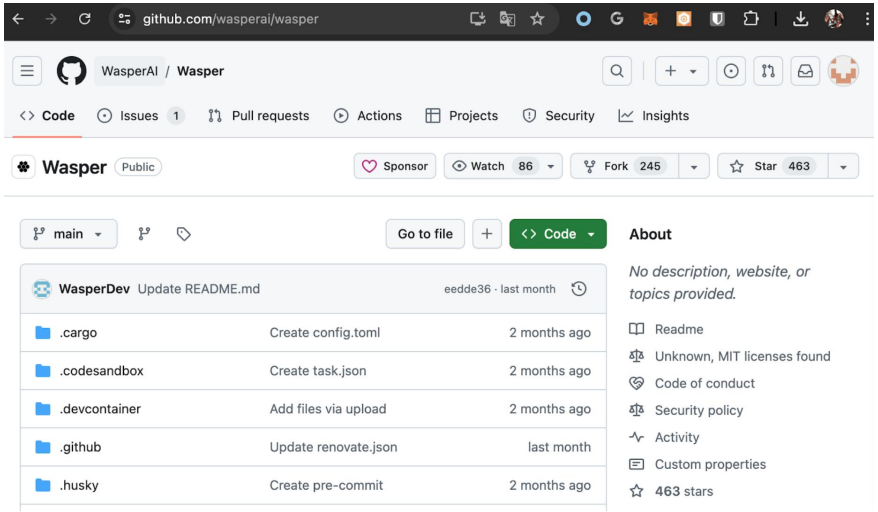
Social Engineering – unknowingly fall into the trap

The attacker chats with the victim on social platforms, recommending "high-quality" projects and guiding the victim to visit a malicious phishing site at https[:]//wasper[.]app, where they download a malicious application.





Social Engineering – unknowingly fall into the trap



Contributing

Bug Reports	Feature Requests	Questions
Create a bug report	Submit a feature request	Send us an Email
Something isn't working as expected	An idea for a new feature, or improvements	contact@wasper.app

Calling all developers, testers, tech writers and more! Contributions of all types are more than welcome, you can read more in docs/types-of-contributions.md. If you are interested in contributing code, read our docs/CONTRIBUTING.md and feel free to check out our GitHub issues to get stuck in to show us what you're made of.

Before you start contributing, please make sure you have read and accepted our Contributor License Agreement. To indicate your agreement, simply edit this file and submit a pull request.

For **bug reports**, **feature requests** and other **suggestions** you can also create a new issue and choose the most appropriate template for your feedback.

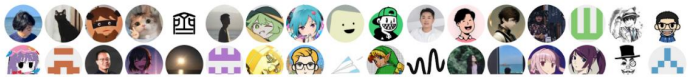
If you have questions, you are welcome to contact us. One of the best places to get more info and learn more is in the Wasper where you can engage with other like-minded individuals.

Ecosystem

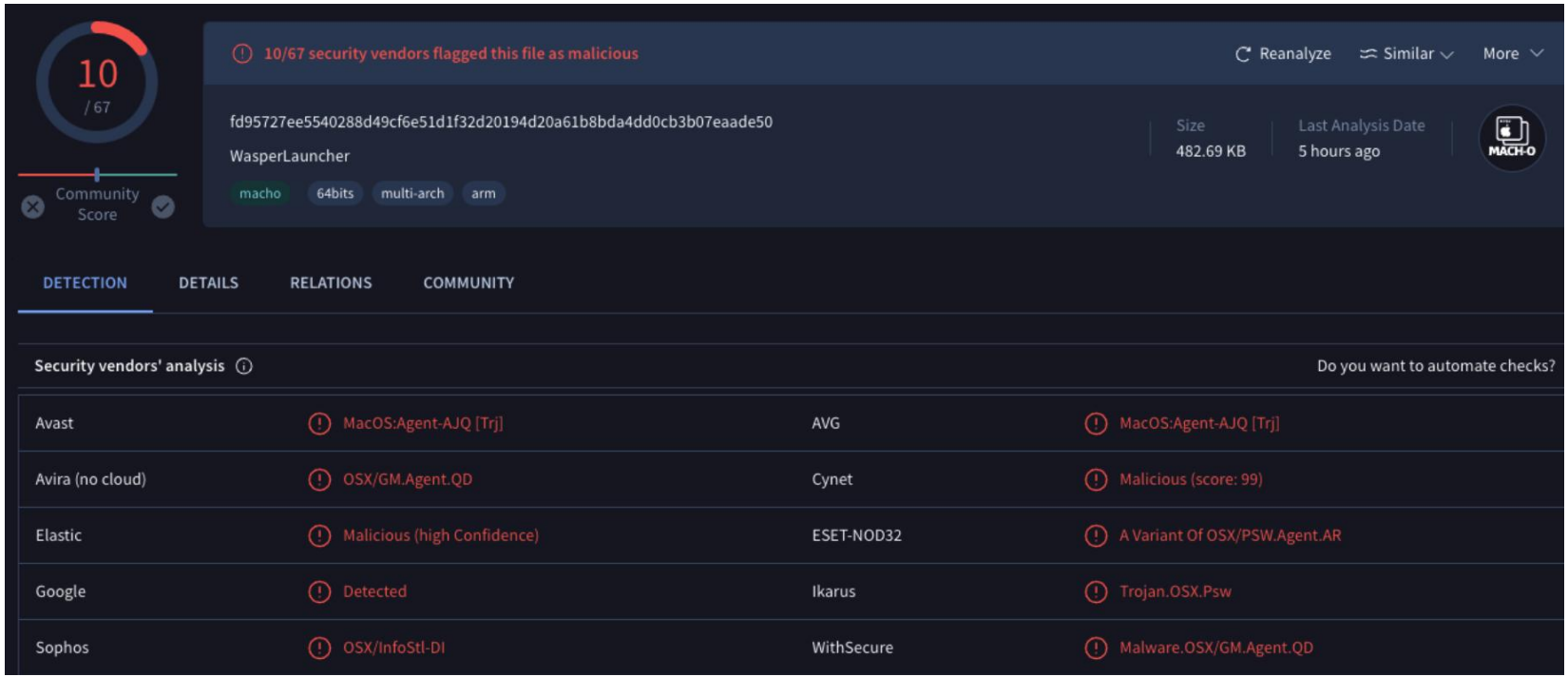
Name		
@wasper/component	Wasper Component Resources	coverage 58%
@wasperai/theme	Wasper theme	downloads 28k/month

Contributors

We would like to express our gratitude to all the individuals who have already contributed to Wasper! If you have any Wasper-related project, documentation, tool or template, please feel free to contribute it by submitting a pull request to our curated list on GitHub: awesome-Wasper.



Social Engineering – unknowingly fall into the trap



Attack

Seize the Opportunity to Intrude -> make the target "have a thought"

- **Curiosity/Greed:** No fear of the "sell high" strategy, don't miss the potential 100x coin, see you tonight at 10 PM, meeting link: https[:]//us04-zoom.us/; Don't miss the $PENGU Airdrop whitelist, https[:]//vote-pengu.com/.
- **Fear:** Urgent alert: XX project has been hacked, please use revake[.]cash to revoke authorizations and avoid financial losses.
- ...



Concealment

Conceal Movements: hide online identity



VPN



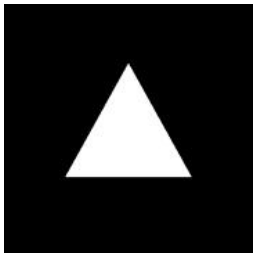
Tor



Zombie

- **Conceal Movements:**
  anonymous procurement of services/infrastructure


Namecheap


Vercel



Netlify


Cloudflare

- **Conceal Movements:**
  mixing coins to hide the fund transfer path



Wasabi Wallet



TornadoCash



Monero

Erase Traces:
avoid leaving samples and evidence after profiting

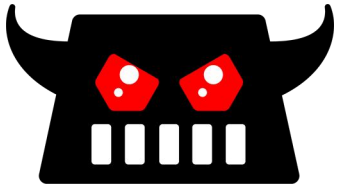
- Delete related domain name resolutions
- Delete malicious programs
- Delete related records (GitHub repositories, platform accounts, etc)

Technique

Common Phishing Tools



Gophish



Evilginx



Evilgophish



Swaks



DNSTwist



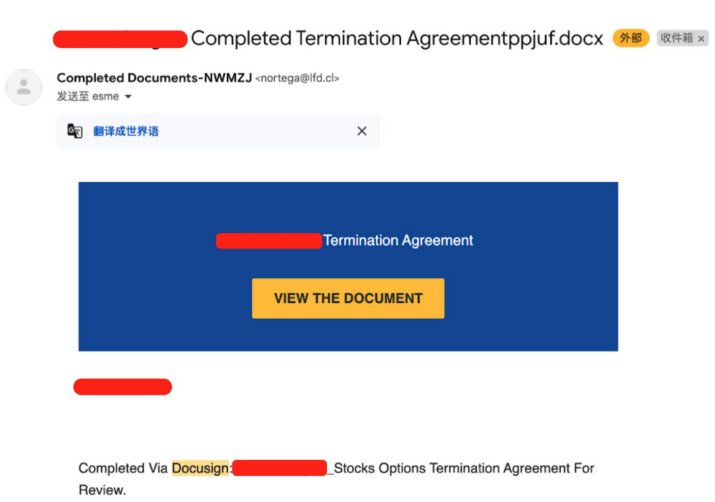
BlackEye

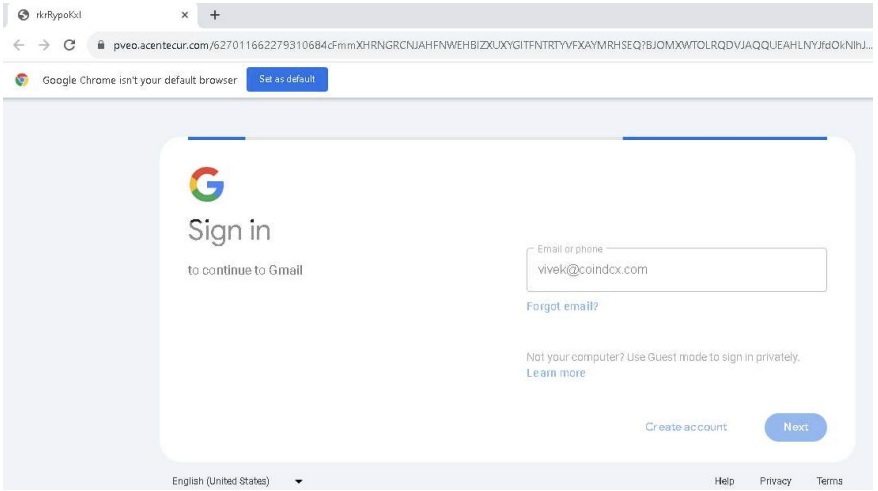
Phishing Templates + Reverse Proxy

shuvo-halder Add files via upload — d110666 · 2 months ago

Name	Last commit message	Last commit date
..		
adobe	Add files via upload	2 months ago
amazon	Add files via upload	4 years ago
apple	Add files via upload	2 months ago
badoo	Add files via upload	4 years ago
bitcoin	Add files via upload	4 years ago
create	Add files via upload	4 years ago
devianart	Add files via upload	4 years ago
dropbox	Add files via upload	4 years ago
facebook	Add files via upload	4 years ago
github	Add files via upload	4 years ago
gitlab	Add files via upload	4 years ago
google	Add files via upload	4 years ago
icloud	Add files via upload	4 years ago
instafollowers	Add files via upload	4 years ago
instagram	Add files via upload	4 years ago
linkedin	Add files via upload	4 years ago
messenger	Add files via upload	4 years ago
microsoft	Add files via upload	4 years ago
myspace	Add files via upload	4 years ago
netflix	Add files via upload	4 years ago
origin	Add files via upload	4 years ago
paypal	Add files via upload	4 years ago
pinterest	Add files via upload	4 years ago
playstation	Add files via upload	4 years ago
protonmail	Add files via upload	4 years ago
shopify	Add files via upload	4 years ago
shopping	Add files via upload	4 years ago
snapchat	Add files via upload	4 years ago
spotify	Add files via upload	4 years ago
steam	Add files via upload	4 years ago
twitch	Add files via upload	4 years ago
twitter	Add files via upload	4 years ago
verizon	Add files via upload	4 years ago
vk	Add files via upload	4 years ago
wifi	Add files via upload	4 years ago

Phishing Templates + Reverse Proxy



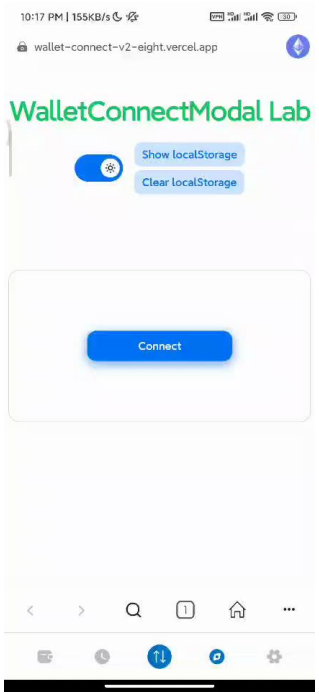


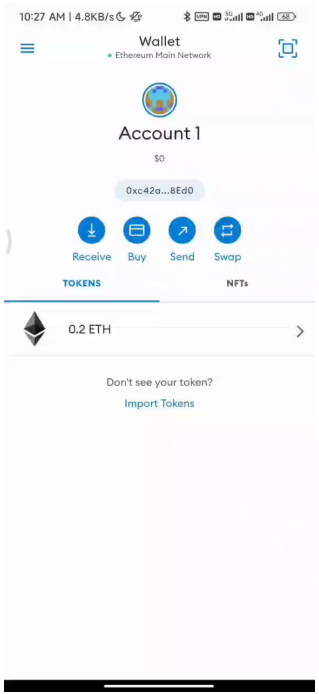
Visual Deception: similar domain names and email spoofing

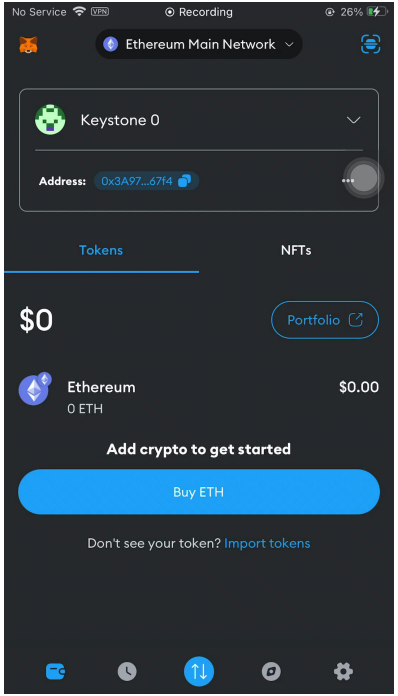




Leveraging Flaws in Web3 Wallets

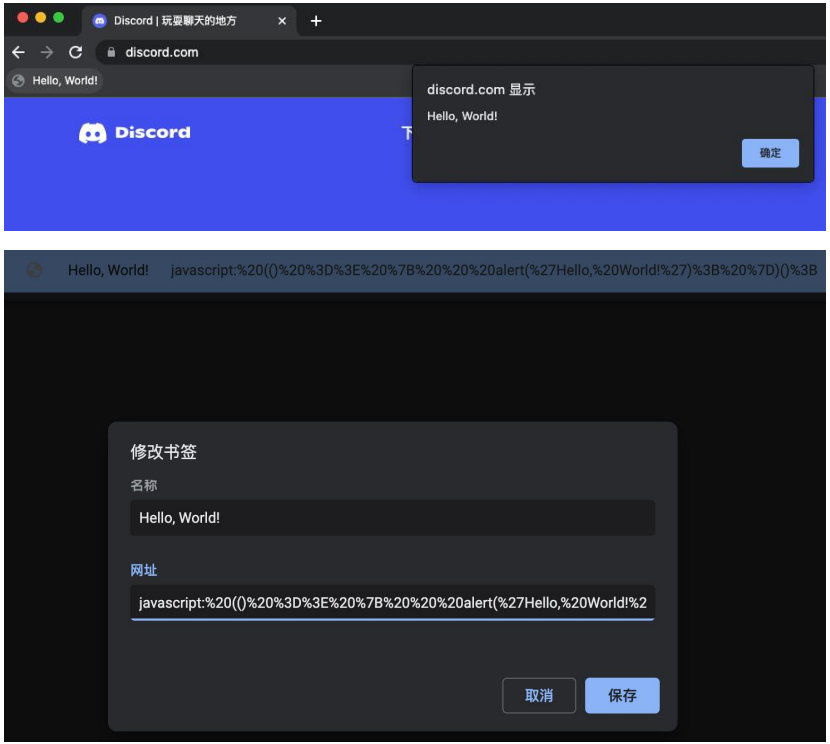






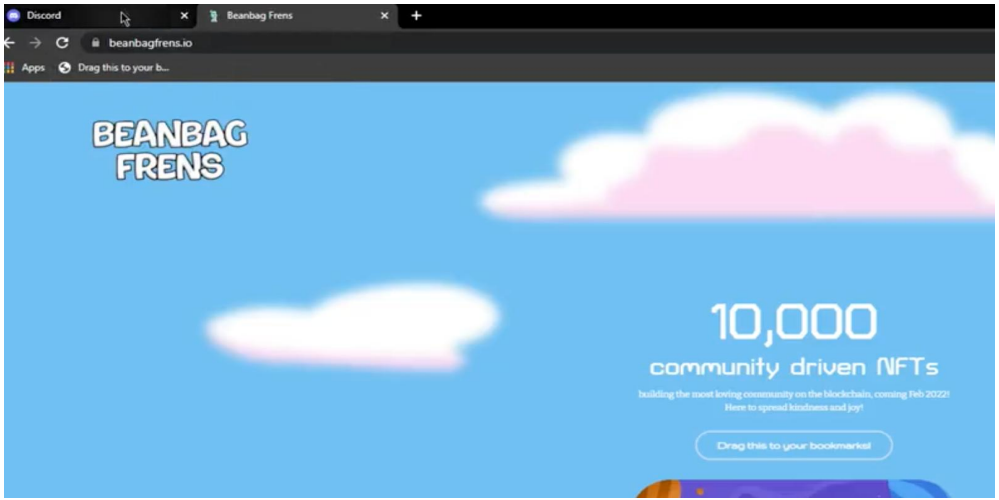
More

Exploiting Browser Features: bookmark phishing

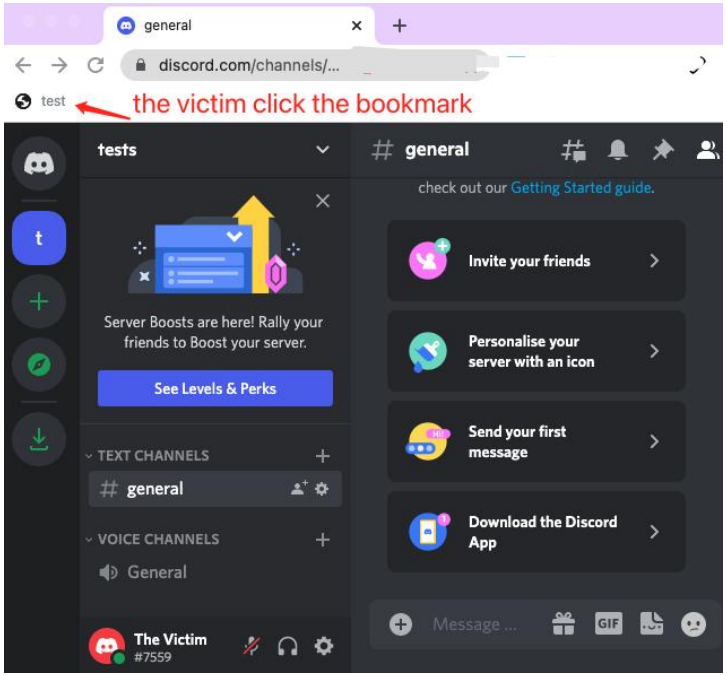


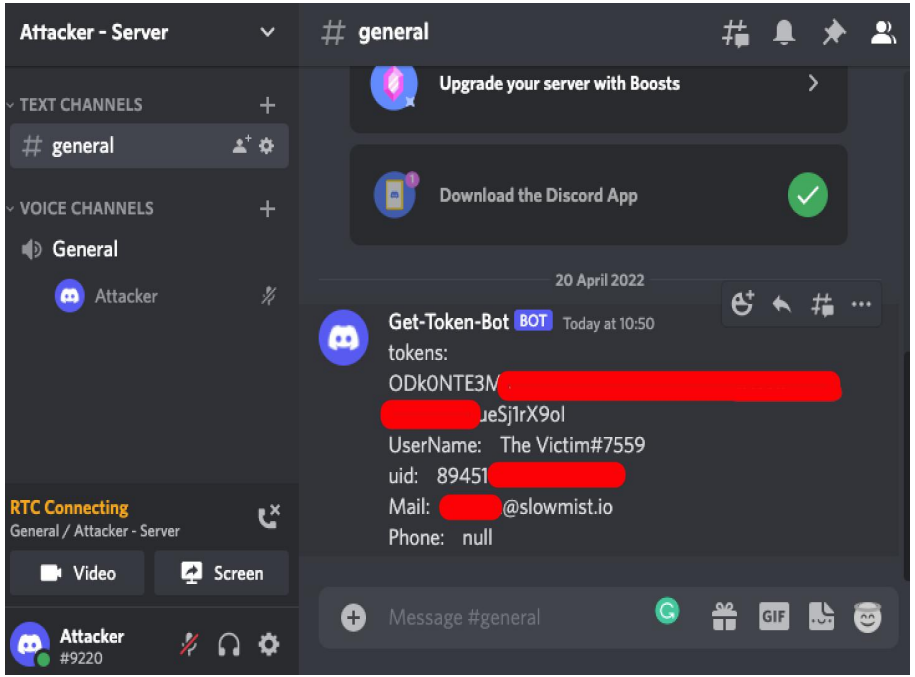
Exploiting Browser Features: bookmark phishing





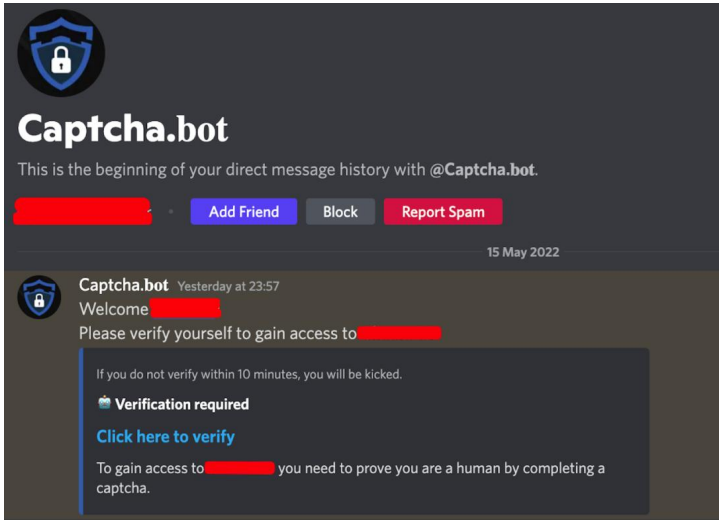
Exploiting Browser Features: bookmark phishing

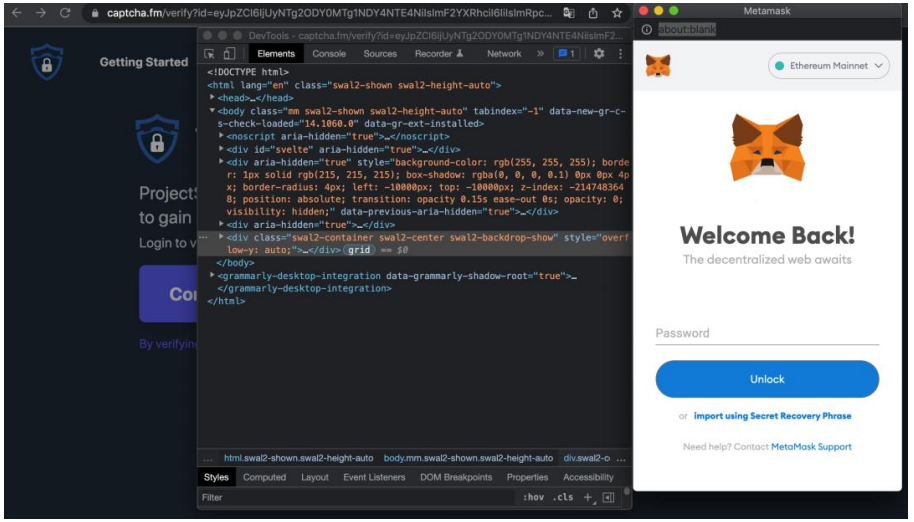




[How Scammer Used Malicious Bookmark to Gain Access to Discords of NFT projects]

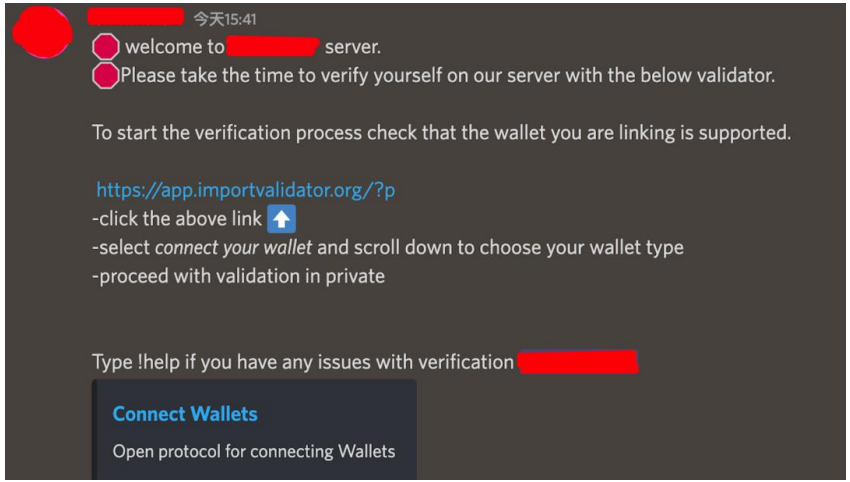
Private Message Phishing: fake CAPTCHA bot

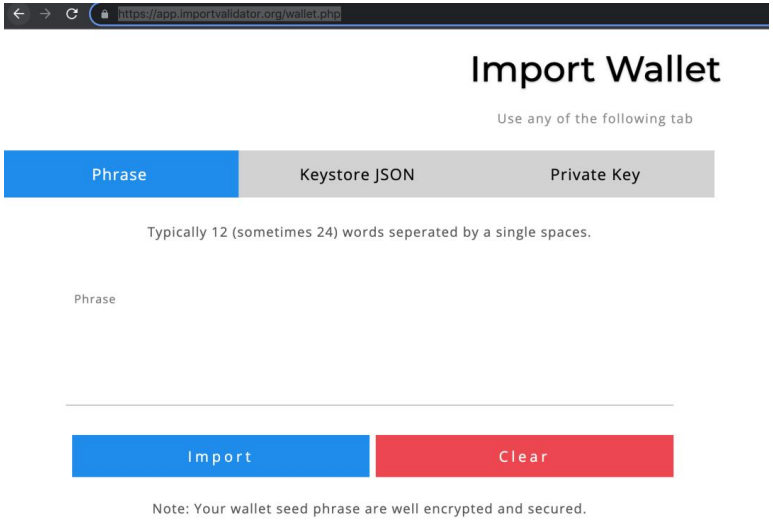




[Discord Phishing Techniques By DM]

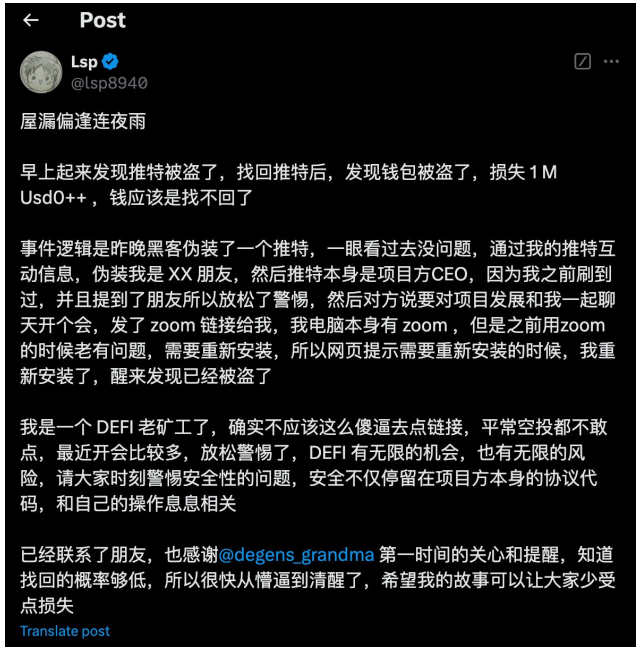
Private Message Phishing: fake official accounts





Discord Phishing Techniques By DM

Private Message Phishing: fake conference apps



（https://x.com/lsp8940/status/1871350801270296709）



（https://x.com/bocaibocai_/status/1841731741175971891）

Seeing is Deceiving | Analysis of Fake Zoom Meeting Phishing Attack

Identification

How to identify if you are being targeted by a phishing attack?



Basic verification:

- Verify the official domain.
- Verify the official project's social media accounts.
- Cross-verify information through multiple reliable channels.
- Check community discussions and reviews.
- Use blockchain explorers to view contract activities.
- Use defensive tools for verification.

How to identify if you are being targeted by a phishing attack?

Common suspicious characteristics:

- Promises of unreasonable high returns.
- Requests for urgent actions or limited-time offers.
- Asking for private keys or mnemonic phrases.
- Airdrop bait from unknown sources.
- Fake project team information.
- Requests for X login and authorization.
- Requests to install applications on computers or mobile phones.



Defense

Defensive Tools



Scam Sniffer



Rabby



AVG



Hardware Wallet

Defense Strategy

- **Zero Trust:** Stay skeptical and maintain that skepticism at all times.
- **Continuous Verification:** Trust in your ability to verify what you doubt, and cultivate this ability into a habit.



Improve Security Awareness



区块链黑暗森林自救手册

Blockchain Dark Forest Selfguard Handbook

Master these, master the security of your cryptocurrency.

- https://darkhandbook.io

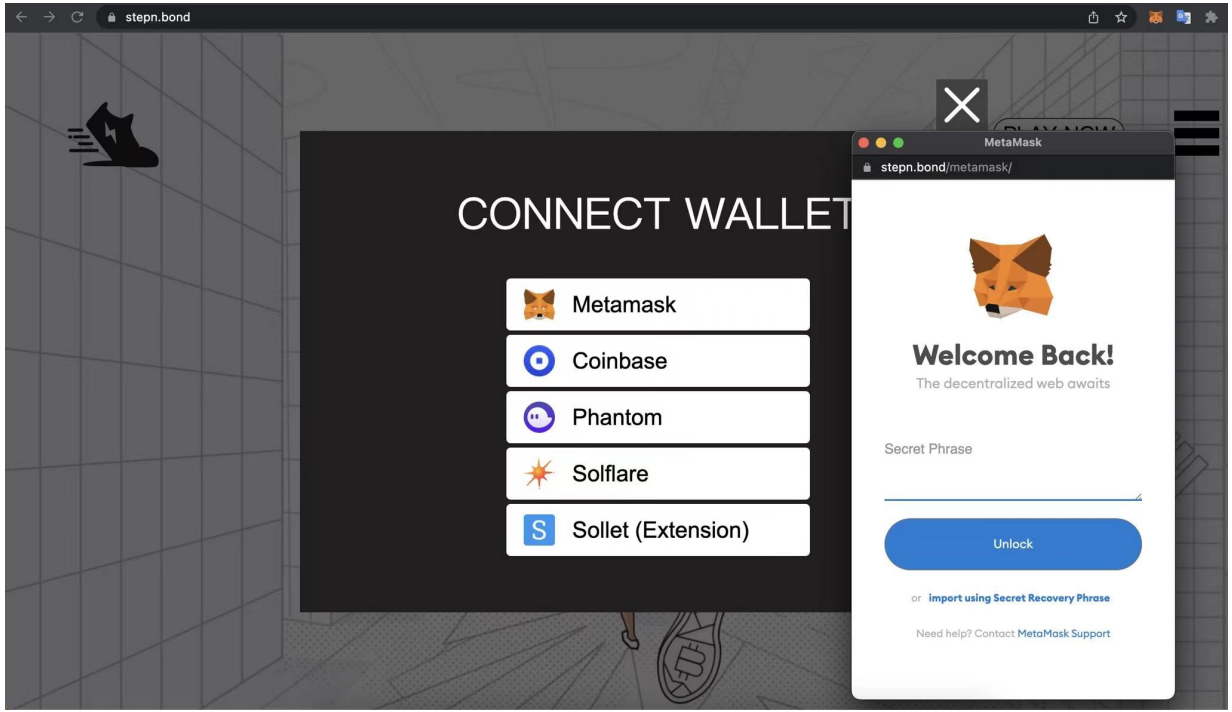
Continuously Monitor Web3 Phishing Techniques

- SlowMist: Security Guide for Securing X Accounts
- How Scammer Used Malicious Bookmark to Gain Access to Discords of NFT projects
- Discord Phishing Techniques By DM
- Small Bait, Big Fish| Unveiling the 1155 WBTC Phishing Incident
- Cracking the Code: Unveiling the Deceptive ‘Angel Drainer’ Phishing Gang
- Cryptocurrency Security Solution by SlowMist
- Seeing is Deceiving | Analysis of Fake Zoom Meeting Phishing Attack
- SlowMist: Beware of WalletConnect Phishing Risks in Web3 Wallets
- Double Deception: Beware of Scammers Posing as Recovery Agents
- SlowMist: How to Choose an Anti-Phishing Plugin
- SlowMist: Analysis of Monkey Drainer NFT Phishing Group
- Analysis of Balancer BGP Hijacking Incident
- An in-depth look into the infrastructure supporting the “fake wallet” phishing industry
- New Scam Alert: Beware of Phishing URLs Disguised as Transfer Addresses
- Unraveling the Sophisticated Phishing Scheme Behind Fake Google Ads


EASTER EGG

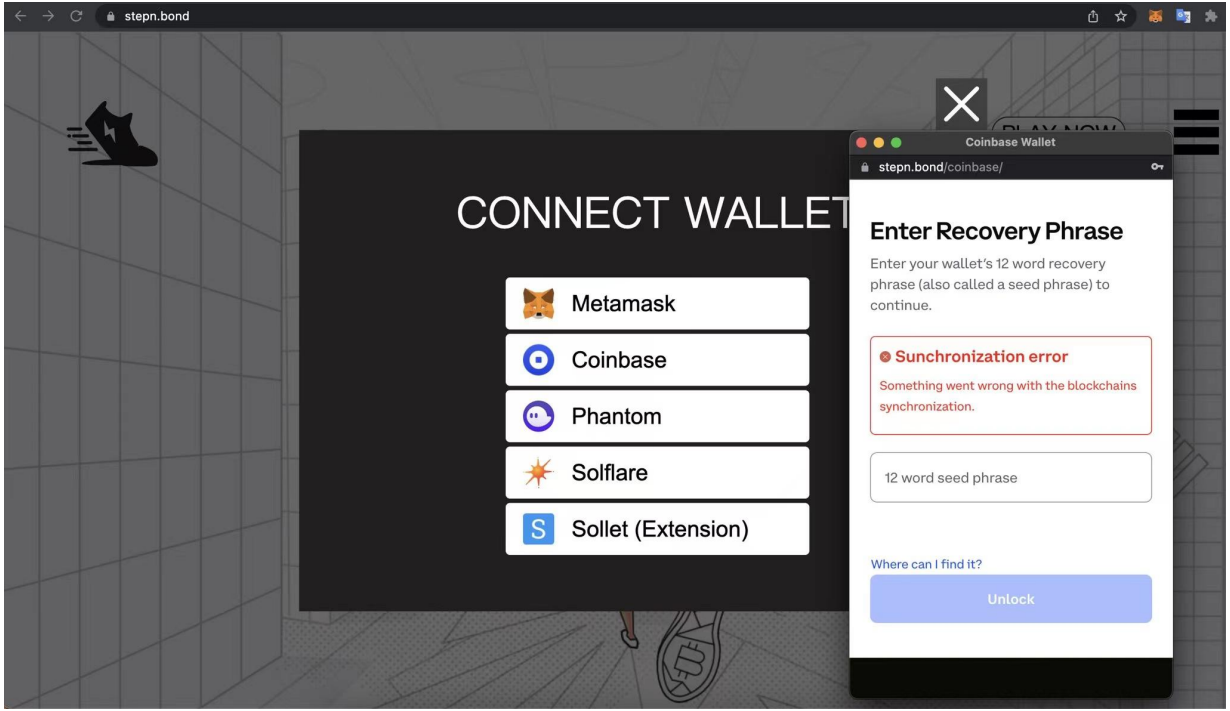
Case 1

- Phishing websites steal mnemonic phrases



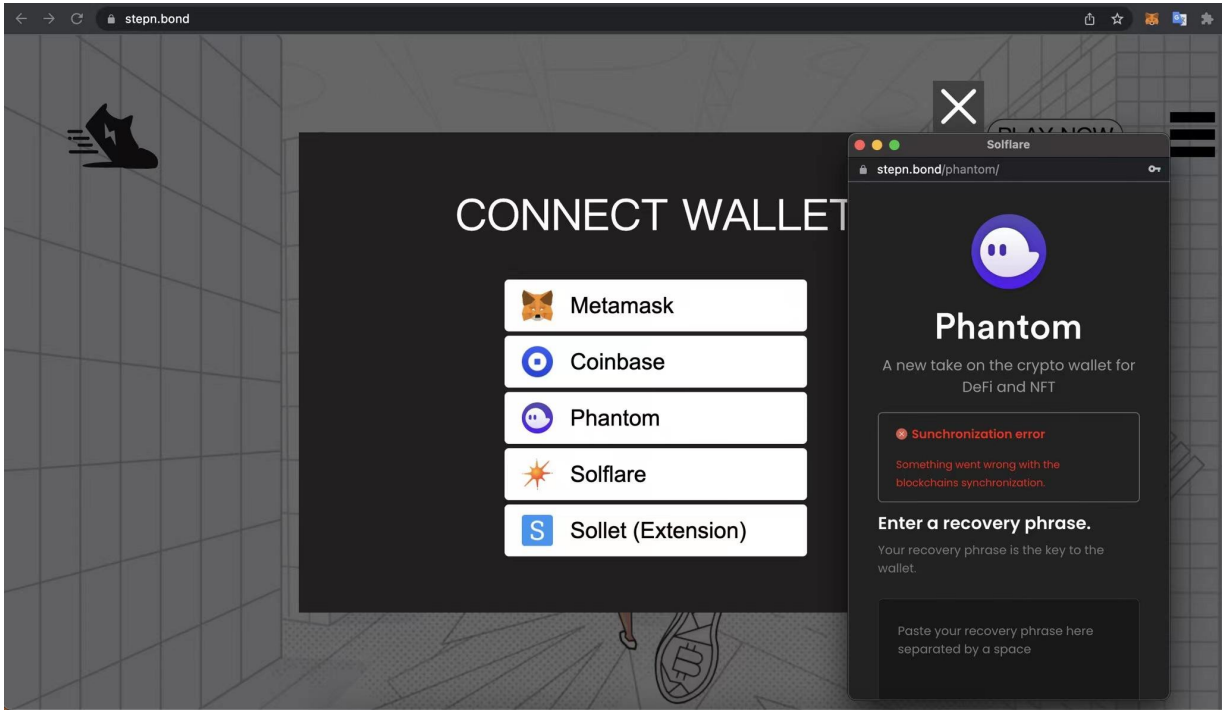
Case 1

- Phishing websites steal mnemonic phrases



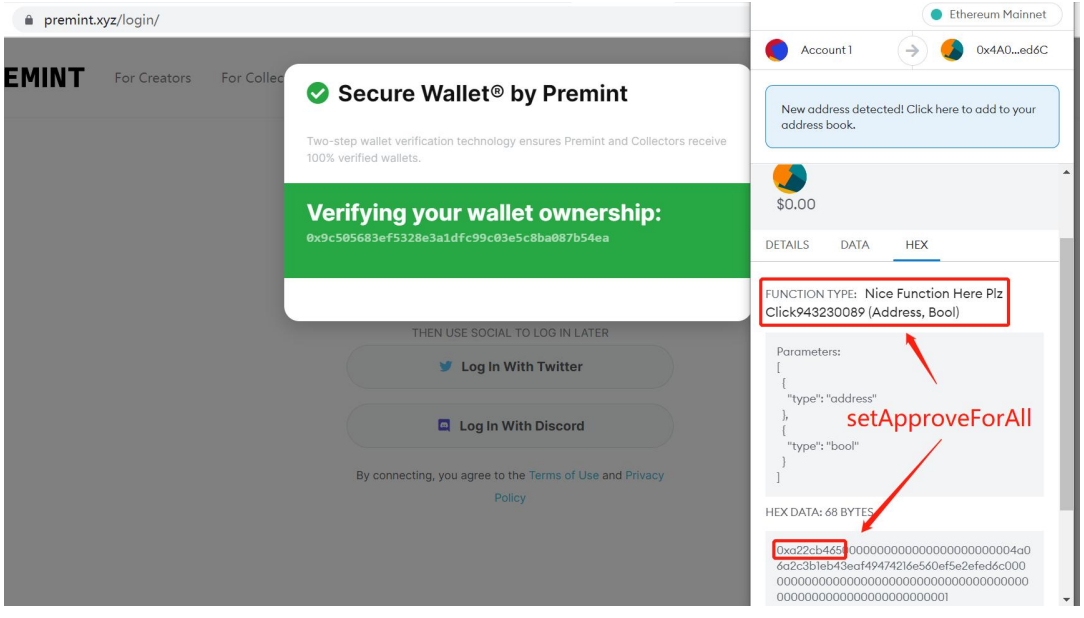
Case 1

- Phishing websites steal mnemonic phrases



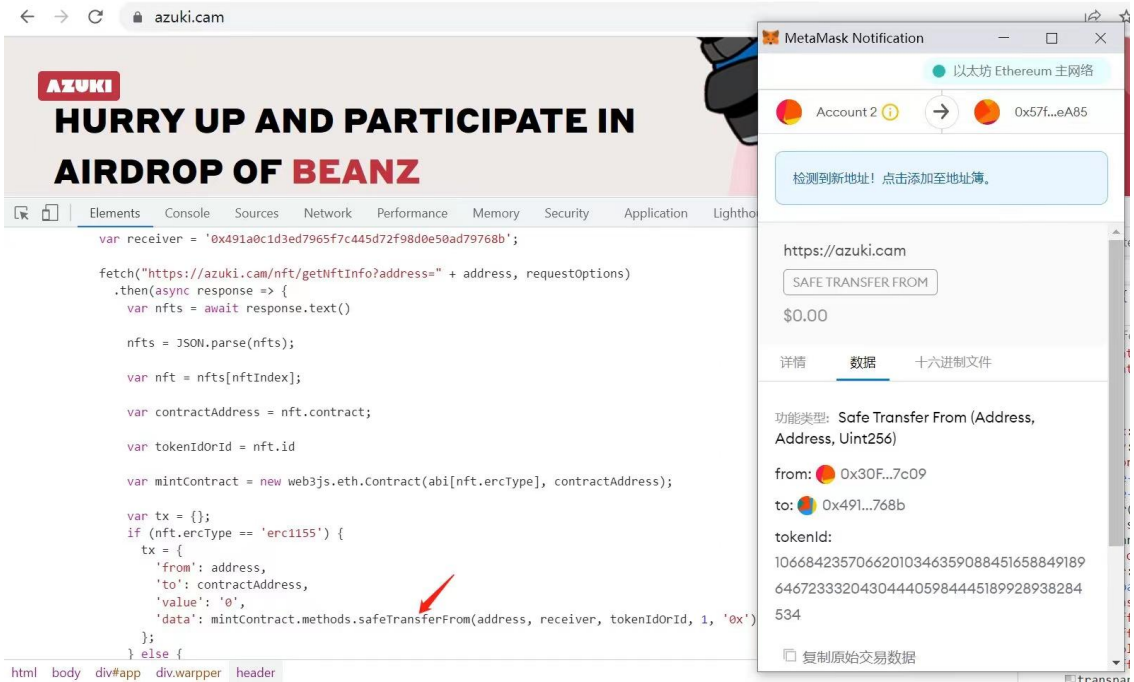
Case 2

- **Approve** is a common mechanism of Ethereum smart contracts(e.g., of ERC20, ERC721, ERC1155, etc).
- Phishing websites can use Approve to carry out token theft attacks.



Case 3

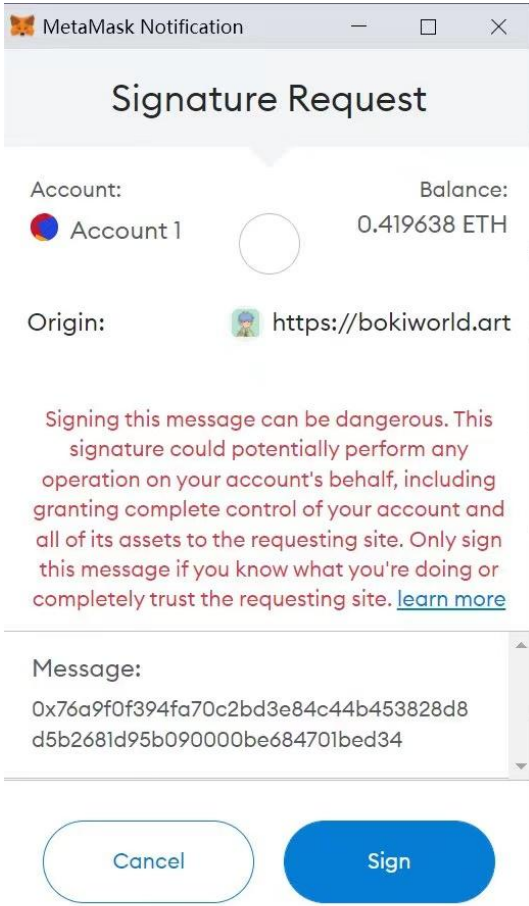
- Phishing websites can use **Transfer** to carry out the ETH/tokens theft attack.



Case 4

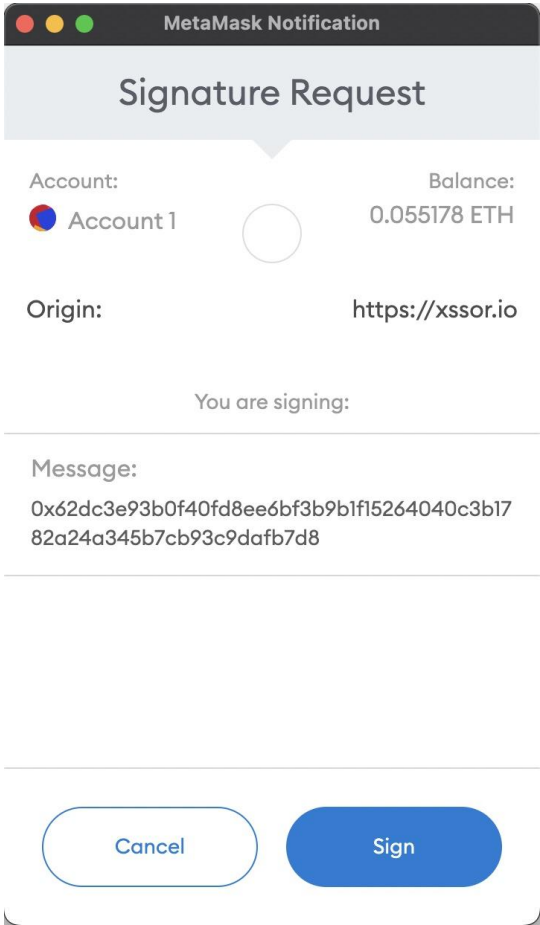
- Phishing websites can use **eth_sign** to carry out the ETH/tokens theft attack.
- **eth_sign** is a low-level signature method of Ethereum, and MetaMask will display a red text alert.
- For the user, the message is just a string of 66 characters beginning with 0x.
- This is a kind of blind sign.

SlowMist: "Blank Check" eth_sign Phishing Analysis



Case 5

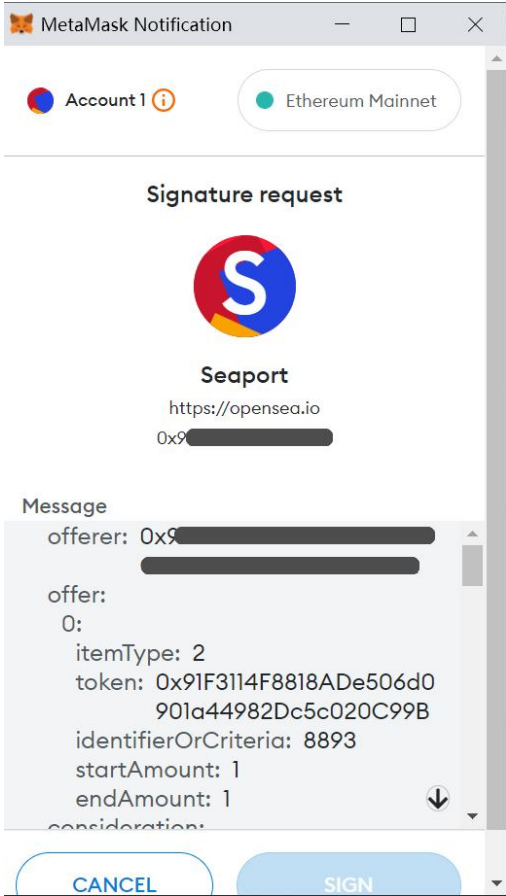
- Phishing websites can use **personal_sign** to carry out the NFTs theft attack.
- The root causes are:
  - Users signed NFT listing requests on NFT Marketplace.
  - Attackers phished to obtain relevant signatures from users.
  - Attackers stole the NFTs of users at very low cost.



Case 6

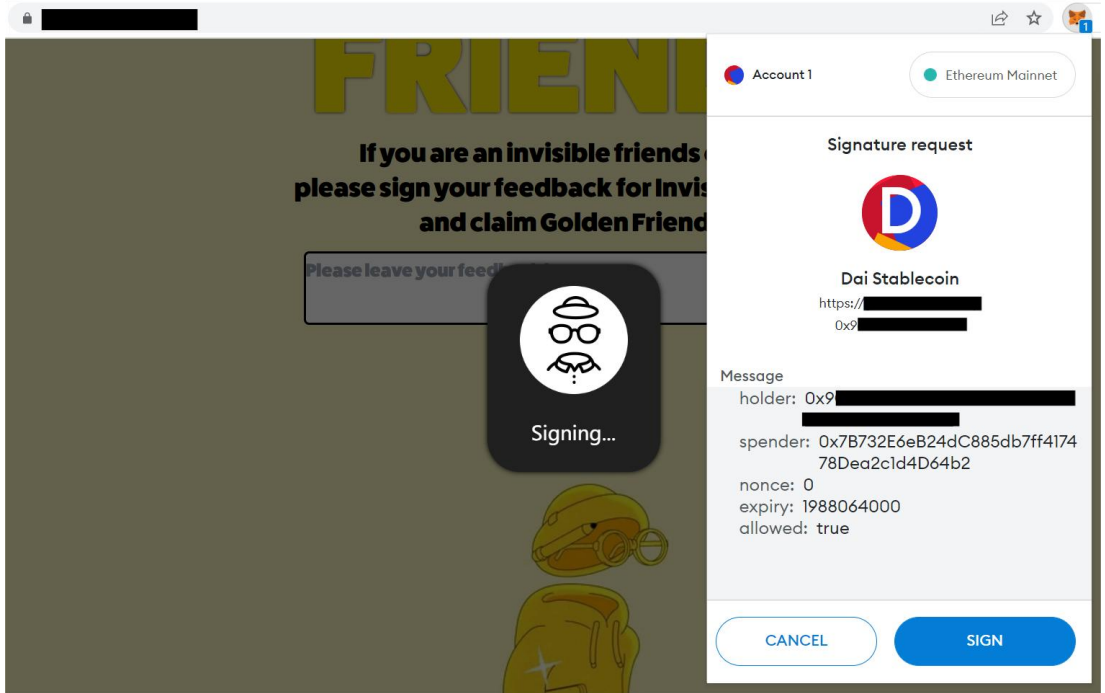
- Phishing websites can use **signTypedData_v4** to carry out the NFTs theft attack.
- The root causes are:
  - Users signed NFT listing requests on NFT Marketplace.
  - Attackers phished to obtain relevant signatures from users.
  - Attackers stole the NFTs of users at very low cost.

https://twitter.com/evilcos/status/1578993566675742721



Case 7

- Signature phishing against **DAI/USDC**
- If signed, the attacker can obtain the signature result (r, s, v values)...



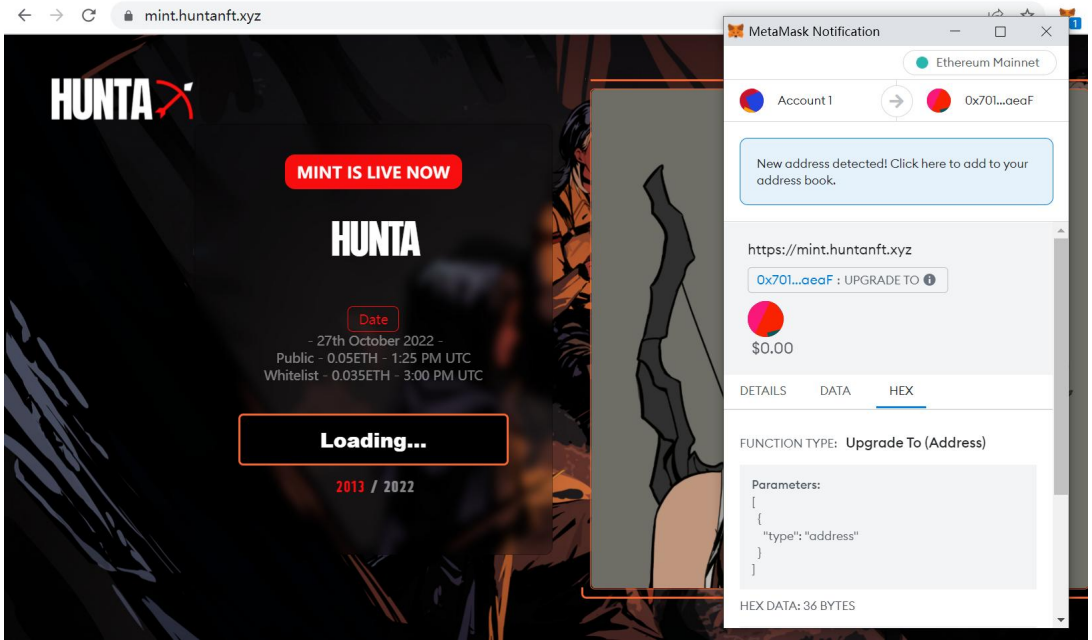
Case 7

- Call the DAI's **permit** function to complete authorization and coin theft:

```
170     // --- Approve by signature ---
171     function permit(address holder, address spender, uint256 nonce, uint256 expiry,
172                     bool allowed, uint8 v, bytes32 r, bytes32 s) external
173     {
174         bytes32 digest =
175             keccak256(abi.encodePacked(
176                 "\x19\x01",
177                 DOMAIN_SEPARATOR,
178                 keccak256(abi.encode(PERMIT_TYPEHASH,
179                                      holder,
180                                      spender,
181                                      nonce,
182                                      expiry,
183                                      allowed))
184         ));
185
186         require(holder != address(0), "Dai/invalid-address-0");
187         require(holder == ecrecover(digest, v, r, s), "Dai/invalid-permit");
188         require(expiry == 0 || now <= expiry, "Dai/permit-expired");
189         require(nonce == nonces[holder]++, "Dai/invalid-nonce");
190         uint wad = allowed ? uint(-1) : 0;
191         allowance[holder][spender] = wad;
192         emit Approval(holder, spender, wad);
193     }
194 }
```

Case 8

- Phishing interacting with upgradeTo of **OwnableDelegateProxy** of OpenSea Wyvern Protocol :-(



Case 8

- Phishing interacting with **upgradeTo** of OwnableDelegateProxy of OpenSea Wyvern Protocol :-(
- Set a malicious implementation address.
- Which gives the hacker permission to withdraw your NFTs.

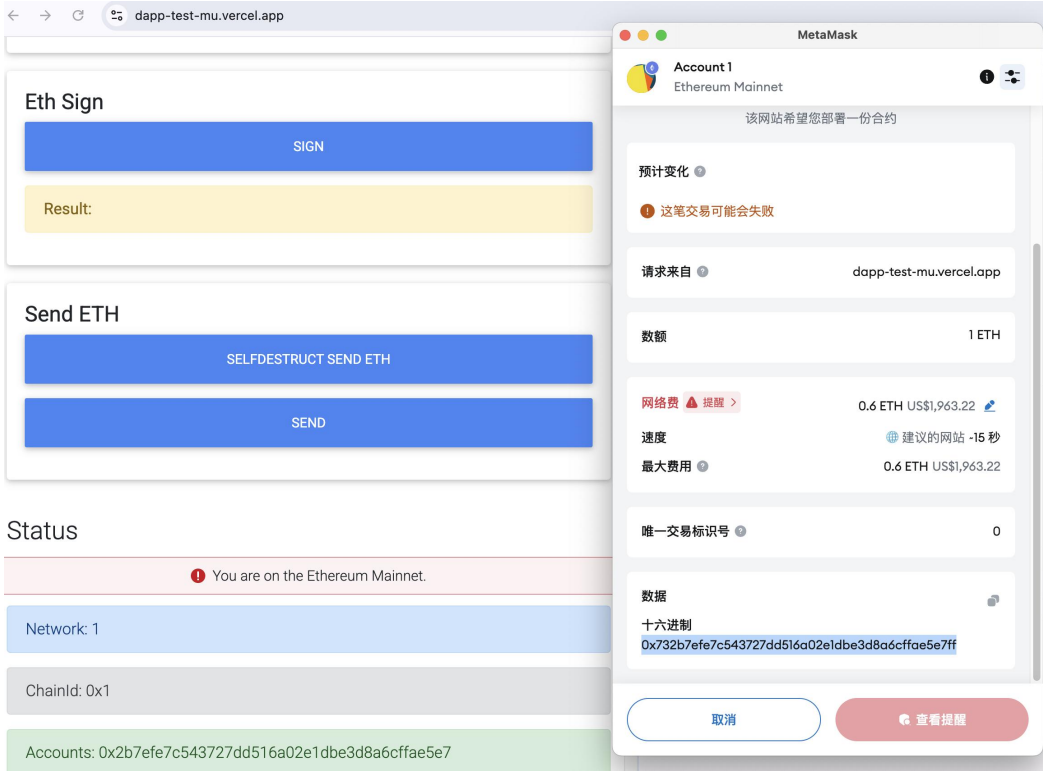
```
136     */
137    function upgradeTo(address implementation) public onlyProxyOwner {
138      _upgradeTo(implementation);
139    }
140
141    /**
142     * @dev Allows the upgradeability owner to upgrade the current implementation of the proxy
143     * and delegatecall the new implementation for initialization.
144     * @param implementation representing the address of the new implementation to be set.
145     * @param data represents the msg.data to bet sent in the low level call. This parameter may include the function
146     * signature of the implementation to be called with the needed payload
147     */
148    function upgradeToAndCall(address implementation, bytes data) payable public onlyProxyOwner {
149      upgradeTo(implementation);
150      require(address(this).delegatecall(data));
151    }
152  }
```

Case 9

73: PUSH20
PUSH(uint160)
pushes a 20-byte value onto the stack

<address>

FF: SELFDESTRUCT
selfdestruct(address(addr))
sends all funds to addr and pre-Cancun hardfork, EIP-7680: destroys the contract



Case 9

```
{
 // JSON-RPC method for sending transaction
 "method": "eth_sendTransaction",

 // Transaction parameters
 "params": [{
  // Sender's Ethereum address
  "from": "0x2b7efe7c543727dd516a02e1dbe3d8a6cffae5e7",

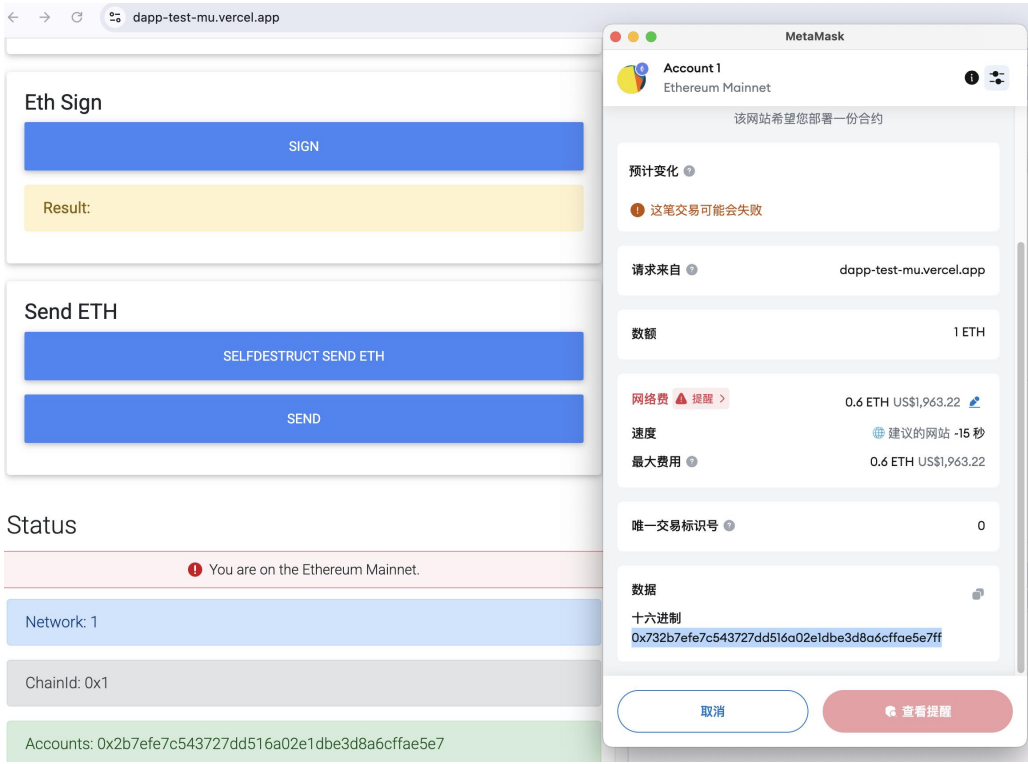
  // Recipient's address (0 indicates contract creation)
  "to": 0,

  // Gas price in wei (10 Gwei)
  "gasPrice": "0x09184e72a000",

  // Gas limit (60,000)
  "gas": "0xea60",

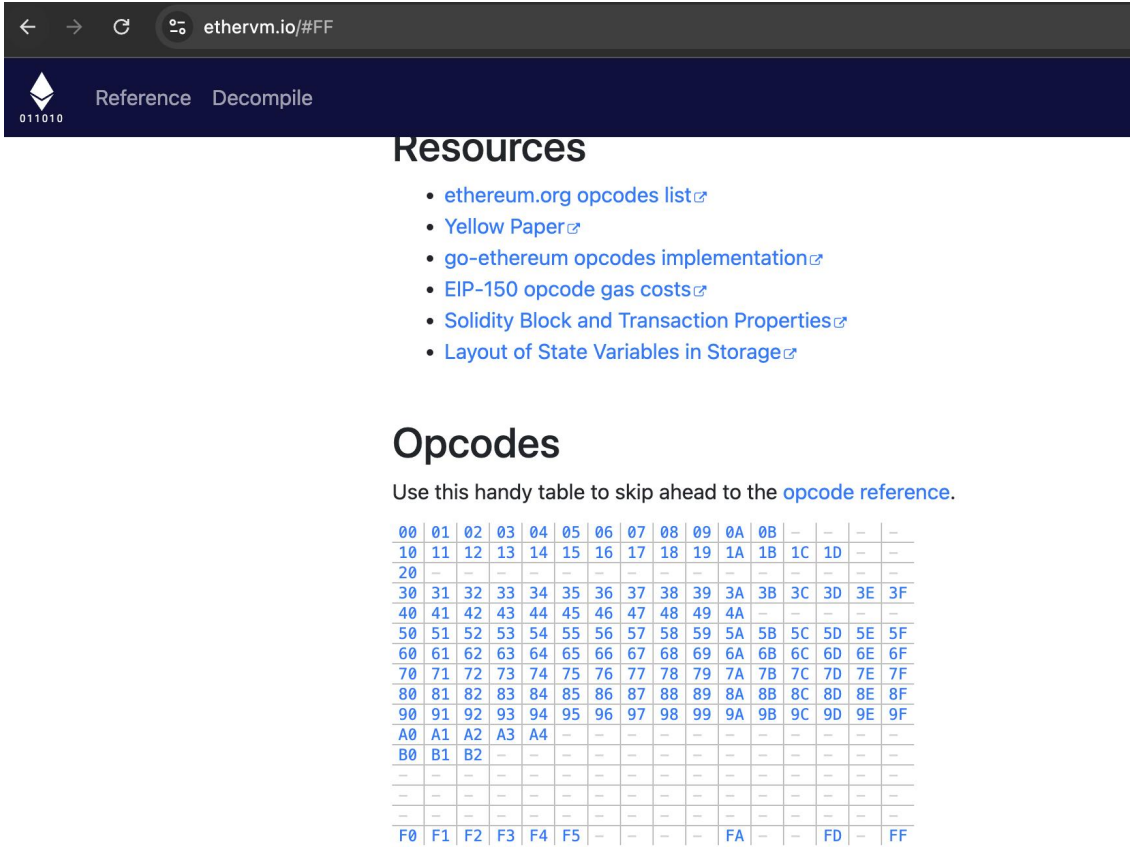
  // Value in wei (1 ETH)
  "value": "0xde0b6b3a7640000",

  // Contract data/input data
  "data":
"0x732b7efe7c543727dd516a02e1dbe3d8a6cffae5e7ff"
 }]
}
```



Case 9

- https://ethervm.io





Official Website
https://slowmist.com

Email
team@slowmist.com

X (Twitter)
@SlowMist_Team

GitHub
https://github.com/slowmist

Medium
https://slowmist.medium.com